МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы регулирования рисков корпоративной системы управления доступом при компрометации учётных записей»

Разработал студент
гр. ИБ-211 «_____» И.М. Ковалев
Подпись, дата Инициалы, фамилия

Руководитель: «_____»
Подпись, дата, должность, инициалы, фамилия

Защищен_____ Оценка_____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей 11
1.1 Исследование корпоративной системы управления доступом и её компонентов 11
1.2 Анализ нормативно-правового обеспечения управления доступом и аутентификации 17
1.3 Анализ уровней доверия аутентификации NIST и практики применения многофакторной аутентификации 20
1.4 Сравнительный анализ средств управления учётными записями и аудита каталогов 23
1.5 Исследование количественных моделей риска применительно к субъектам доступа 26
1.6 Обоснование противоречий и формулировка задач работы 29
СПИСОК ЛИТЕРАТУРЫ 34

ВВЕДЕНИЕ

Корпоративная система управления доступом объединяет службу каталога, средства идентификации и аутентификации, механизмы авторизации и процессы управления жизненным циклом учётных записей, посредством которых работники организации получают доступ к защищаемым информационным ресурсам. Основной учётной единицей такой системы выступает учётная запись субъекта доступа: именно к ней привязываются членство в группах, назначенные роли, делегированные полномочия и признаки доверия, на основании совокупности которых система принимает решение о предоставлении доступа к ресурсу.

Принципиальная особенность корпоративной системы управления доступом как объекта защиты состоит в том, что её компрометация не требует преодоления средств защиты информации в привычном понимании. Нарушитель, получивший аутентификационные данные легитимного пользователя, действует в пределах полномочий, назначенных этому пользователю штатным порядком, вследствие чего его действия слабо отличимы от обычной работы работника организации и не выявляются средствами, ориентированными на обнаружение признаков вредоносного программного обеспечения. Тем самым величина ущерба определяется не свойствами применённого нарушителем инструмента, а объёмом полномочий, накопленных скомпрометированной учётной записью.

Значимость данного класса угроз подтверждается отраслевой статистикой. Согласно отчёту Verizon Data Breach Investigations Report за 2025 год [1], 22 % нарушений безопасности информации начинались с использования украденных учётных данных, а человеческий фактор присутствовал в 60 % расследованных инцидентов. Отечественная статистика утечек информации фиксирует ту же тенденцию [2]. По данным исследования Positive Technologies [3], с кибератаками в течение года столкнулись 55 % российских организаций, а результаты тестов на проникновение показывают, что в 96 % случаев специалисты получают полный доступ ко всей инфраструктуре организации [4], причём развитие атаки внутри

периметра выполняется преимущественно легитимными учётными записями и штатными средствами администрирования.

Отдельную проблему образует накопление полномочий субъектами доступа. При переводах работников между подразделениями, временных замещениях, совмещении обязанностей и участии в проектах права выдаются оперативно, а отзываются с задержкой либо не отзываются вовсе. В результате фактический объём полномочий учётной записи со временем превышает необходимый для исполнения должностных обязанностей, а последствия её компрометации возрастают многократно. Процесс этот носит постепенный характер и не сопровождается событиями безопасности, вследствие чего не обнаруживается средствами мониторинга, реагирующими на отдельные действия.

Применяемые в организациях средства управления учётными записями и привилегированным доступом - системы классов IdM, IGA и PAM, а также средства аудита служб каталога - решают задачи предоставления, отзыва и контроля прав и выявляют формальные несоответствия ролевой модели. Результатом их работы является перечень отклонений с дискретной оценкой соответствия по каждой учётной записи в отдельности. Такая оценка не отвечает на вопрос о том, какова вероятность компрометации конкретной учётной записи, какой ущерб наступит при её компрометации и какие последовательности перемещений нарушителя по ролям и группам приводят его к полномочиям администратора и к защищаемым информационным ресурсам.

Нормативную основу оценки надёжности подтверждения личности образуют руководство NIST SP 800-63B [5], вводящее уровни доверия аутентификации AAL1-AAL3 и требования к применяемым факторам, и ГОСТ Р 58833 [6], устанавливающий общие положения идентификации и аутентификации. Указанные документы задают требования к механизмам подтверждения личности, однако не содержат количественной меры риска, позволяющей сопоставить учётные записи между собой и упорядочить их по величине ожидаемого ущерба.

Степень проработанности темы. Вопросы риск-анализа в области защиты информации получили развитие в трудах отечественной научной школы, в которых

разработаны методики оценки частоты и ущербности компьютерных атак [7], предложен аппарат формализации знаний и данных об атаках и уязвимостях [8], введено понятие риск-ландшафта сетевых атак и обоснованы подходы к его регулированию [9]. Матричная формализация целеполагания проектной деятельности [10] и научно-методические рекомендации по формированию технических заданий в области обеспечения информационной безопасности [11] задают структуру постановки задач настоящего исследования. Международная практика представлена методиками менеджмента риска [12-13], руководством NIST по проведению оценки рисков [14], методиками OCTAVE Allegro [15] и факторной моделью FAIR [16]. Вместе с тем перечисленные работы оперируют преимущественно уязвимостями программного обеспечения и сетевыми атаками, тогда как субъект доступа, обладающий накопленным объёмом полномочий, не рассматривается в них как самостоятельная единица риск-анализа, а применяемые средства управления доступом ограничиваются контролем соответствия ролевой модели без оценки индуцируемого риска.

Актуальность темы исследования обусловлена наличием противоречий между:

- существующим информационным обеспечением проектной деятельности по управлению рисками корпоративной системы управления доступом и необходимостью его совершенствования в части покрытия потребностей проактивного риск-анализа при компрометации учётных записей;

- существующими методиками риск-анализа корпоративной системы управления доступом и необходимостью их совершенствования в части учёта проактивных принципов оценки риска нарушения информационной безопасности при компрометации учётных записей с использованием методов машинного обучения;

- существующими методиками управления рисками нарушения информационной безопасности корпоративной системы управления доступом и необходимостью их совершенствования в части проактивного регулирования риска на основе результатов машинного обучения;

- имеющимися средствами автоматизации оценки и регулирования рисков корпоративной системы управления доступом и необходимостью их совершенствования для оценки эффективности предлагаемых технических решений в части проактивного экспресс-анализа процессов управления риском.

Объектом исследования является корпоративная система управления доступом, включающая службу каталога, средства идентификации и аутентификации, механизмы авторизации и разграничения прав, ролевую модель организации и процессы управления жизненным циклом учётных записей субъектов доступа.

Предметом исследования являются модели, методики и алгоритмы проактивной оценки и регулирования рисков нарушения информационной безопасности, позволяющие количественно описывать вероятность компрометации учётной записи и величину наступающего при этом ущерба, а также поддерживать полученные оценки в актуальном состоянии при изменении состава полномочий.

Целью исследования является повышение защищённости корпоративной системы управления доступом за счёт разработки интеллектуальной системы регулирования рисков, обеспечивающей количественную оценку риска компрометации учётных записей, построение риск-ландшафта субъектов доступа и выбор мер защиты по критерию предотвращаемого ущерба.

Для достижения поставленной цели необходимо решить следующие задачи:

- создать информационное обеспечение, покрывающее потребности проектной деятельности по проактивному управлению рисками нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей;

- создать аналитическое обеспечение проактивного риск-анализа нарушений информационной безопасности корпоративной системы управления доступом, учитывающее специфику компрометации учётных записей и накопления полномочий и возможности предиктивных моделей машинного обучения;

- создать аналитическое обеспечение проактивного управления рисками нарушения информационной безопасности корпоративной системы управления

доступом, учитывающее результаты оценки первичного риска и специфику компрометации учётных записей;

- сформировать средства автоматизации, предназначенные для проактивного экспресс-анализа процессов оценки и регулирования рисков нарушения информационной безопасности корпоративной системы управления доступом, и выполнить оценку эффективности предлагаемых мер защиты.

Методы исследования. При решении поставленных задач применялись методы системного анализа и декомпозиции сложных систем, аппарат теории рисков и факторная модель FAIR [16], методы теории вероятностей и математической статистики, аппарат теории графов при построении дерева угроз и цепочек компрометации, методы машинного обучения без учителя при выявлении аномального накопления полномочий, методы экспертного оценивания, а также методы объектно-ориентированного программирования при разработке программного обеспечения.

Решение поставленных задач позволяет получить следующие результаты, выносимые на защиту:

- необходимое и достаточное для решения задач работы информационное обеспечение проактивного риск-анализа корпоративной системы управления доступом при компрометации учётных записей;

- аналитическое обеспечение проактивной оценки риска нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей;

- аналитическое обеспечение проактивного регулирования риска нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей;

- средства автоматизации предложенных методик оценки и регулирования риска нарушения информационной безопасности корпоративной системы управления доступом, а также оценка эффективности разработанных мер защиты.

Новизна полученных результатов заключается в следующем:

- предлагаемое информационное обеспечение, в отличие от аналогов, формализует описание компонентов системы управления доступом, свойств учётных записей и ролей, сценариев компрометации и источников данных в едином составе, ориентированном на проактивный риск-анализ, а не на последующий разбор произошедших инцидентов;

- разработанное аналитическое обеспечение оценки риска, в отличие от аналогов, учитывает при расчёте первичного риска на основе факторной модели FAIR результаты предиктивной модели машинного обучения, выявляющей аномальное накопление полномочий;

- разработанное аналитическое обеспечение регулирования риска, в отличие от аналогов, предусматривает автоматизированный выбор мер защиты с учётом их масштабности и профильности и расчёт остаточного риска с последующей количественной верификацией;

- созданные средства автоматизации, в отличие от аналогов, позволяют в автоматическом режиме выполнять полный цикл проактивного управления риском - от идентификации сценария компрометации до количественной верификации эффективности выбранных мер защиты.

Практическая ценность полученных результатов состоит в следующем:

- структура и состав предложенного информационного обеспечения могут быть практически использованы при построении систем проактивного управления рисками корпоративной системы управления доступом;

- предложенные методики риск-анализа позволяют получать количественную оценку первичного риска нарушения информационной безопасности до наступления компрометации учётной записи и упорядочивать субъекты доступа по величине ожидаемого ущерба;

- предложенная аналитика управления рисками применима для поддержки принятия решений по выбору мер защиты корпоративной системы управления доступом с учётом их экономической эффективности;

- созданные средства автоматизации необходимы для внедрения проактивного подхода к управлению рисками корпоративной системы управления доступом и применимы при обосновании состава мер защиты.

Теоретическая значимость результатов исследования определяется следующим образом:

- методики сбора и обработки данных, предложенные в работе, могут быть развиты применительно к сервисным и машинным идентичностям и федеративному доступу;

- разработанные методики риск-анализа целесообразно развить в части учёта иных классов угроз и новых способов подтверждения личности;

- предложенную аналитику управления рисками перспективно расширить по составу учитываемых мер защиты и сценариев компрометации учётных записей;

- созданный инструментарий допускает адаптацию для систем управления доступом с иными моделями разграничения прав.

Информационную базу исследования составляют нормативные правовые акты и методические документы ФСТЭК России, национальные стандарты в области защиты информации и менеджмента риска, руководства NIST SP 800-63B, NIST SP 800-53 и NIST SP 800-30, матрица MITRE ATT&CK, перечни CWE и CAPEC, спецификации систем CVSS и EPSS, факторная модель анализа информационного риска FAIR, ежегодные отраслевые отчёты об инцидентах информационной безопасности, а также публикации отечественной научной школы в области риск-анализа и регулирования рисков кибератак.

Апробация результатов. Результаты исследования планируются к докладу на научно-практических конференциях и семинарах, проводимых кафедрой систем информационной безопасности, а также к обсуждению в рамках научно-исследовательской работы обучающихся.

Публикация результатов. Результаты исследования планируются к опубликованию в научном журнале «Информация и безопасность», а также в сборниках трудов научно-практических конференций.

Настоящая работа выполнена в объёме научно-исследовательской работы и содержит введение, первую главу выпускной квалификационной работы и список литературы. В первой главе исследуются корпоративная система управления доступом и её компоненты, нормативно-правовое обеспечение управления доступом и аутентификации, уровни доверия аутентификации и практика применения многофакторной аутентификации, существующие средства управления учётными записями и количественные модели риска, выявляются противоречия и ставятся задачи работы. Решение поставленных задач составляет содержание второй - пятой глав выпускной квалификационной работы: вторая глава посвящена созданию информационного обеспечения проактивного риск-анализа, третья - аналитическому обеспечению проактивной оценки рисков, четвёртая - аналитическому обеспечению проактивного регулирования рисков, пятая - автоматизации предложенных методик и обоснованию эффективности мер защиты. Такое построение воспроизводит последовательность проактивного управления риском: информационное обеспечение задаёт множество учитываемых свойств учётных записей и сценариев их компрометации, аналитическое обеспечение оценки переводит их в первичный риск, аналитическое обеспечение регулирования - в выбор мер защиты и остаточный риск, а средства автоматизации обеспечивают выполнение этой последовательности при каждом изменении состава полномочий и количественную верификацию принятых решений.

1 Исследование аналогов и постановка задач работы в области проактивного управления рисками нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей

Настоящая глава посвящена исследованию аналогов и обоснованию целеполагания работы. В соответствии с научно-методическими рекомендациями по выполнению работ в области обеспечения информационной безопасности [11] её назначение состоит в подробном обосновании противоречий, положенных в основу исследования, и в постановке задач, решение каждой из которых составляет содержание последующих глав. Исследование опирается на терминологию, принятую в национальных стандартах и отечественной научной школе [17], согласно которой безопасность есть состояние защищённости от внешних и внутренних угроз, при котором риск реализации этих угроз не превышает допустимых значений; угроза - совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации; ущерб - совокупность негативных последствий реализации угроз; риск - возможность наступления ущерба от реализации угроз, а мера риска определяется произведением величины ожидаемого ущерба на вероятность его наступления.

Изложение строится в следующем порядке: рассматриваются корпоративная система управления доступом и её компоненты, нормативно-правовое обеспечение управления доступом и аутентификации, уровни доверия аутентификации и практика применения многофакторной аутентификации, существующие средства управления учётными записями и аудита каталогов, количественные модели риска, после чего выявляются противоречия и формулируются задачи работы.

1.1 Исследование корпоративной системы управления доступом и её компонентов

Под корпоративной системой управления доступом в настоящей работе понимается совокупность программных, технических и организационных средств,

обеспечивающих идентификацию субъектов доступа, подтверждение их личности, предоставление и отзыв полномочий в отношении защищаемых информационных ресурсов организации, а также регистрацию связанных с этим событий. Система управления доступом не является отдельным продуктом: она складывается из службы каталога, средств аутентификации, механизмов авторизации, средств управления жизненным циклом учётных записей и средств контроля привилегированного доступа, работающих совместно.

Ключевое отличие рассматриваемого объекта от иных объектов защиты состоит в том, что решение о предоставлении доступа принимается системой не по свойствам обращающегося субъекта, а по свойствам предъявленной учётной записи. Учётная запись выступает посредником между работником организации и защищаемым ресурсом, и любое лицо, предъявившее её аутентификационные данные, приобретает связанные с ней полномочия в полном объёме. Вследствие этого учётная запись является одновременно средством разграничения доступа и точкой сосредоточения риска: величина возможных последствий определяется не тем, кто её использует, а тем, какие полномочия к ней привязаны.

В составе системы управления доступом целесообразно выделить следующие компоненты, различающиеся назначением и характером хранимых сведений о субъектах доступа:

- служба каталога - централизованное хранилище сведений об учётных записях, группах, организационных подразделениях и назначенных ролях, выступающее источником истины при принятии решения о доступе;

- подсистема идентификации и аутентификации - средства подтверждения личности субъекта доступа, включая парольную защиту, средства многофакторной аутентификации и аппаратные носители ключевой информации;

- подсистема авторизации - ролевая модель организации, политики доступа и правила, определяющие, какие действия разрешены субъекту в отношении конкретного ресурса;

- подсистема управления жизненным циклом учётных записей - средства класса IdM и IGA, выполняющие создание, изменение, согласование и отзыв полномочий в связи с кадровыми событиями;

- подсистема управления привилегированным доступом - средства класса PAM, обеспечивающие выдачу административных полномочий на ограниченное время, хранение учётных данных административных записей и запись сессий;

- подсистема регистрации событий и аудита - средства сбора сведений о входах, изменениях состава полномочий и обращениях к защищаемым ресурсам.

Перечисленные компоненты, характер хранимых ими сведений о субъекте доступа и последствия их компрометации сведены в таблицу 1.

Таблица 1 - Компоненты корпоративной системы управления доступом и последствия их компрометации

Компонент	Назначение	Сведения о субъекте доступа	Последствия компрометации
Служба каталога	Хранение сведений об учётных записях, группах и ролях	Идентификатор, состав групп, атрибуты записи	Изменение состава полномочий любого субъекта доступа
Подсистема идентификации и аутентификации	Подтверждение личности субъекта доступа при входе	Применяемые факторы, уровень доверия аутентификации	Вход нарушителя от имени работника организации
Подсистема авторизации	Принятие решения о доступе к ресурсу	Назначенные роли и разрешённые действия	Доступ к ресурсам в обход установленных правил
Подсистема управления жизненным циклом	Предоставление и отзыв полномочий по кадровым событиям	История выдачи и отзыва прав, согласования	Самовольное расширение полномочий без согласования
Подсистема управления привилегированным доступом	Выдача административных полномочий на ограниченное время	Факты и записи административных сессий	Получение полномочий администратора инфраструктуры
Подсистема регистрации событий и аудита	Регистрация входов, изменений прав и обращений к ресурсам	Время, место и результат обращений субъекта	Сокрытие следов действий нарушителя

Учётные записи, обслуживаемые системой управления доступом, неоднородны по назначению и по применяемым к ним правилам подтверждения личности. Наряду с пользовательскими записями работников в службе каталога

присутствуют административные записи, сервисные записи прикладных систем, технологические записи регламентных заданий и записи внешних субъектов - подрядчиков и представителей контрагентов. Различие между ними существенно для риск-анализа: правила парольной политики и требования к факторам аутентификации применяются к ним в различном объёме, а владелец, отвечающий за своевременный отзыв полномочий, определён не для каждого типа.

Сервисные и технологические записи заслуживают отдельного внимания. Их аутентификационные данные хранятся в конфигурационных файлах прикладных систем и в средствах автоматизации, смена этих данных требует согласованного изменения настроек нескольких систем и поэтому откладывается, а второй фактор подтверждения личности к ним неприменим по условиям работы. Вследствие этого сервисные записи обладают долгоживущими полномочиями, за которые не отвечает определённый владелец, а технологические позволяют нарушителю закрепиться в инфраструктуре, не создавая событий, характерных для работы пользователя. Внешние записи подрядчиков и контрагентов подтверждают личность вне контура организации, и контроль их жизненного цикла, включая своевременный отзыв прав, оказывается наиболее слабым.

Состав полномочий учётной записи не является постоянным: он формируется на протяжении всего времени работы субъекта доступа в организации и изменяется при каждом кадровом событии.

Учётная запись создаётся при приёме работника на работу и наделяется базовым набором полномочий, соответствующим занимаемой должности. В дальнейшем при переводе в другое подразделение, совмещении обязанностей, временном замещении отсутствующего работника и участии в проектах субъекту доступа выдаются дополнительные полномочия. Выдача полномочий выполняется оперативно, поскольку от неё зависит исполнение работником своих обязанностей, тогда как отзыв выполняется с задержкой либо не выполняется вовсе: он никем не инициируется, не связан с ощутимым для подразделения результатом и не контролируется автоматически.

Накопление полномочий носит не случайный, а системный характер и обусловлен устройством процессов управления доступом. Заявка на предоставление прав подаётся и согласуется, заявка на их отзыв в типовом процессе отсутствует; аттестация прав проводится эпизодически и сводится к формальному подтверждению руководителем текущего состояния; временные полномочия выдаются без указания срока действия. В результате объём полномочий учётной записи монотонно возрастает, а ущерб, наступающий при её компрометации, возрастает вместе с ним, оставаясь при этом неизмеренным.

Способ, которым полномочия связываются с субъектом доступа, определяется принятой в организации моделью разграничения доступа. Исторически первой применялась дискреционная модель, в которой права назначает владелец объекта доступа; её развитием стала мандатная модель, связывающая доступ с метками конфиденциальности. В корпоративных системах управления доступом преобладает ролевая модель, в которой права назначаются роли, а роль - субъекту, что позволяет описывать полномочия работника перечнем ролей, а не перечнем отдельных разрешений. Атрибутная модель, вычисляющая решение о доступе по атрибутам субъекта, ресурса и среды обращения, применяется преимущественно в облачных и гибридных средах. С точки зрения количественной оценки риска эти модели неравноценны: в дискреционной модели права рассредоточены по объектам доступа и сводный перечень полномочий субъекта отсутствует, мандатная модель не отражает накопления прав внутри одного уровня конфиденциальности, а в атрибутной фактический объём прав определяется только вычислением по всем правилам политики.

Ролевая модель, принимаемая в настоящей работе в качестве основной, обладает свойством, существенным для риск-анализа: она задаёт эталон, с которым можно сопоставить фактический состав полномочий субъекта доступа. Работники, занимающие одинаковые должности в одном подразделении, должны обладать сопоставимым набором ролей, и отклонение от этого набора поддаётся измерению без участия эксперта. Именно это свойство используется в третьей главе работы при выявлении аномального накопления полномочий.

Вместе с тем ролевая модель в действующей системе управления доступом редко сохраняется в первоначальном виде. Её эрозия происходит по нескольким направлениям: права назначаются субъекту напрямую в обход ролей, когда согласование новой роли требует времени; группы вкладываются одна в другую, вследствие чего членство в группе передаёт права транзитивно и фактический объём полномочий перестаёт быть очевидным; полномочия, выданные на время проекта, сохраняются после его завершения; администрирование отдельных подразделений делегируется, создавая пути повышения привилегий, не предусмотренные ролевой моделью.

Практическое следствие эрозии состоит в том, что перечень ролей, утверждённый в организационно-распорядительных документах, не может использоваться как источник сведений о полномочиях субъекта доступа. Исходными данными для оценки риска должен служить фактический состав прав, вычисленный по службе каталога с раскрытием вложенности групп и с учётом прямых назначений.

Для последующей формализации введём обозначения. Пусть S - множество субъектов доступа организации, R - множество ролей, определённых в ролевой модели, P - множество элементарных полномочий в отношении защищаемых ресурсов, A - множество защищаемых информационных ресурсов. Каждому субъекту s из множества S соответствует подмножество назначенных ролей, а каждой роли - подмножество элементарных полномочий, вследствие чего фактический объём полномочий субъекта определяется объединением полномочий всех назначенных ему ролей и полномочий, выданных ему непосредственно. Ущерб от компрометации учётной записи субъекта s определяется значимостью тех ресурсов из множества A, которые достижимы при использовании этого объединения.

Обстоятельства, определяющие риск компрометации конкретной учётной записи, неоднородны и распадаются на несколько групп свойств:

- свойства полномочий - количество назначенных ролей и элементарных прав, наличие административных полномочий, доля прав, не используемых субъектом фактически;

- свойства аутентификации - применяемые факторы подтверждения личности, уровень доверия аутентификации, давность смены пароля, наличие исключений из парольной политики;

- свойства активности - регулярность входов, характерные время и место обращения к ресурсам, длительность простоя учётной записи;

- свойства соответствия ролевой модели - отклонение состава полномочий субъекта от состава полномочий работников, занимающих аналогичные должности;

- свойства значимости достижимых ресурсов - категории обрабатываемой на достижимых ресурсах информации и последствия нарушения её конфиденциальности, целостности и доступности.

Перечисленные свойства образуют пространство признаков субъекта доступа, в котором в дальнейшем выполняется количественная оценка риска и выявление аномального накопления полномочий. Существенно, что все они доступны для автоматического извлечения из службы каталога и журналов регистрации событий, то есть не требуют экспертного описания каждой учётной записи в отдельности.

1.2 Анализ нормативно-правового обеспечения управления доступом и аутентификации

Требования, относящиеся к управлению доступом и подтверждению личности субъектов, закреплены в документах нескольких уровней. Доктрина информационной безопасности Российской Федерации [18] определяет защиту информации как условие устойчивого функционирования организаций, Федеральный закон «Об информации, информационных технологиях и о защите информации» [19] устанавливает обязанность обладателя информации ограничивать доступ к ней, а Федеральный закон «О персональных данных» [20] относит разграничение доступа к числу обязательных мер защиты персональных данных.

Состав конкретных мер защиты задают приказы ФСТЭК России, устанавливающие требования к государственным информационным системам [21], информационным системам персональных данных [22] и значимым объектам критической информационной инфраструктуры [23]. Меры разнесены по группам, из которых предмету настоящей работы непосредственно соответствуют группа ИАФ, объединяющая идентификацию и аутентификацию субъектов доступа, и группа УПД, объединяющая управление доступом субъектов к объектам доступа. Состав этих мер и их отражение в риск-анализе приведены в таблице 2.

Таблица 2 - Меры защиты информации групп ИАФ и УПД и их отражение в риск-анализе

Код меры	Содержание меры защиты информации	Отражение в риск-анализе
ИАФ.1	Идентификация и аутентификация пользователей и субъектов доступа	Перечень субъектов доступа как множество единиц риск-анализа
ИАФ.3	Управление идентификаторами, включая создание, присвоение и уничтожение	Признак наличия действующих идентификаторов уволенных работников
ИАФ.4	Управление средствами аутентификации, включая их выдачу и замену	Уровень доверия аутентификации и давность смены средства
ИАФ.6	Идентификация и аутентификация внешних пользователей	Повышенная вероятность компрометации записей подрядчиков
УПД.1	Управление учётными записями, включая их заведение и удаление	Полнота отзыва полномочий при кадровых событиях
УПД.2	Реализация необходимых методов и правил разграничения доступа	Ролевая модель как эталон состава полномочий субъекта
УПД.4	Разделение полномочий пользователей и администраторов	Признак привилегированности учётной записи
УПД.5	Назначение минимально необходимых прав и привилегий	Величина отклонения состава прав от минимально необходимого
УПД.6	Ограничение неуспешных попыток входа в информационную систему	Оценка стойкости к подбору аутентификационных данных
УПД.13	Реализация защищённого удалённого доступа субъектов доступа	Достижимость учётной записи из внешних сетей

Для отдельных отраслей состав требований к управлению доступом детализирован. Национальный стандарт ГОСТ Р 57580.1 [24] устанавливает для финансовых организаций требования к процессам управления доступом, включая регистрацию субъектов доступа, контроль состава предоставленных прав и регулярный пересмотр полномочий, а также вводит уровни защиты информации,

различающиеся полнотой реализуемых мер. Постановление Правительства Российской Федерации о требованиях к защите персональных данных [25] задаёт уровни защищённости, от которых зависит состав применяемых мер разграничения доступа.

Организационная составляющая нормативного обеспечения представлена документами самой организации: политикой управления доступом, матрицей доступа субъектов к информационным ресурсам, регламентом предоставления и отзыва полномочий и порядком проведения периодической аттестации прав. Эти документы определяют, кто согласует выдачу полномочий, в какие сроки они отзываются при кадровых событиях и с какой периодичностью пересматриваются. Практическая значимость перечисленных документов для риск-анализа состоит в том, что они задают эталонное состояние системы управления доступом, отклонение от которого и подлежит измерению.

Существенно, что требования нормативных документов адресованы процессу, а не отдельной учётной записи. Проверка выполнения меры устанавливает, что процедура пересмотра прав предусмотрена и выполняется, но не отвечает на вопрос, какие именно учётные записи накопили избыточные полномочия к моменту проверки и в каком порядке эти полномочия следует сокращать. Разрыв между процессной формой требований и потребностью в пообъектной количественной оценке образует основание первого и второго противоречий настоящей работы.

Методика оценки угроз безопасности информации ФСТЭК России [26] определяет порядок определения актуальных угроз исходя из возможностей нарушителя и наличия сценариев их реализации, а банк данных угроз безопасности информации [27] содержит описания угроз, значительная часть которых связана с получением и использованием чужих аутентификационных данных. Государственные стандарты [28-29] задают классификацию уязвимостей и правила их описания, относя недостатки настройки механизмов защиты к уязвимостям конфигурации, а ГОСТ Р 58833 [6] устанавливает общие положения идентификации и аутентификации, вводя понятия уровня доверия к результатам идентификации и аутентификации.

Международная практика представлена стандартами менеджмента риска [12-13], определяющими общий цикл оценки и обработки риска, и каталогом мер защиты NIST SP 800-53 [30], в котором управлению доступом и идентификации отведены самостоятельные семейства мер. Руководство NIST SP 800-30 [14] описывает порядок проведения оценки рисков, оставляя способ количественного выражения риска на усмотрение организации.

Сопоставление перечисленных документов показывает следующее. Нормативное обеспечение исчерпывающе определяет, какие механизмы управления доступом должны быть реализованы и какие свойства аутентификации должны быть обеспечены, однако устанавливает требования в терминах наличия или отсутствия меры. Ни один из рассмотренных документов не задаёт способа количественного сопоставления учётных записей между собой: из факта выполнения меры не следует оценка вероятности компрометации конкретной записи и величины ущерба, наступающего при её использовании нарушителем. Это обстоятельство образует первое основание для постановки задач настоящей работы.

1.3 Анализ уровней доверия аутентификации NIST SP 800-63 и практики применения многофакторной аутентификации

Руководство NIST SP 800-63 [5] разделяет требования к цифровой идентичности на три независимых измерения: уровень доверия к процедуре установления личности, уровень доверия к процедуре аутентификации и уровень доверия к передаче сведений о личности между системами. Для целей настоящей работы существенным является второе измерение, обозначаемое AAL, поскольку именно оно характеризует стойкость подтверждения личности при каждом входе и, следовательно, вероятность того, что учётной записью воспользуется не её владелец.

Руководство выделяет три уровня доверия аутентификации. Уровень AAL1 допускает подтверждение личности одним фактором, уровень AAL2 требует двух факторов различной природы, уровень AAL3 дополнительно требует, чтобы один из

факторов представлял собой аппаратный криптографический носитель, устойчивый к воспроизведению и к перехвату. Требования уровней и сохраняющиеся при каждом из них способы компрометации приведены в таблице 3.

Таблица 3 - Уровни доверия аутентификации и сохраняющиеся способы компрометации учётной записи

Уровень	Требования к факторам подтверждения личности	Сохраняющиеся способы компрометации	Типовая область применения
AAL1	Один фактор: пароль либо одноразовый код	Подбор и повторное использование пароля, фишинг, утечки баз учётных данных	Технологические и сервисные записи
AAL2	Два фактора различной природы, один из которых криптографический	Фишинг в реальном времени, перехват одноразового кода, утомление подтверждениями	Рядовые учётные записи работников
AAL3	Два фактора, один из которых аппаратный носитель, стойкий к воспроизведению	Физический доступ к носителю, компрометация рабочего места пользователя	Административные и привилегированные записи

Практика применения многофакторной аутентификации в корпоративных системах неоднородна. Наиболее распространены одноразовые коды, передаваемые сообщением или формируемые приложением, и подтверждения входа в мобильном приложении. Оба способа относятся к уровню AAL2 и сохраняют уязвимость к фишингу в реальном времени, при котором нарушитель воспроизводит страницу входа и передаёт полученный код в подлинную систему немедленно. Подтверждения в приложении дополнительно уязвимы к утомлению подтверждениями, когда нарушитель, располагая паролем, инициирует вход многократно, добиваясь ошибочного подтверждения работником.

Устойчивость к перечисленным способам компрометации обеспечивают протоколы, привязывающие аутентификацию к адресу проверяющей стороны, и аппаратные носители ключевой информации, соответствующие уровню AAL3. Их применение в корпоративной практике ограничено стоимостью носителей и необходимостью поддержки на всех рабочих местах, вследствие чего типовой является ситуация, при которой различные группы субъектов доступа одной

организации защищены различными уровнями доверия аутентификации: административные учётные записи - аппаратными носителями, рядовые - паролем и одноразовым кодом, отдельные технологические записи - только паролем.

Уровень доверия аутентификации определяется не только составом применяемых факторов, но и свойствами протокола, которым результат подтверждения личности передаётся прикладным системам. В корпоративных сетях одновременно применяются несколько протоколов, различающихся по стойкости: устаревший протокол, передающий производную от пароля величину, основной протокол службы каталога, работающий на билетах, каталожный протокол доступа к сведениям об учётных записях и протоколы единого входа, применяемые для внешних и облачных сервисов.

Каждому из перечисленных протоколов соответствуют характерные техники компрометации, описанные в матрице MITRE ATT&CK [31] в составе тактик получения учётных данных и закрепления. Передача производной от пароля величины позволяет нарушителю действовать от имени субъекта, не восстанавливая пароль. Получение билетов служб даёт возможность подбирать пароли сервисных учётных записей в автономном режиме, не создавая событий неуспешного входа. Компрометация ключа службы выдачи билетов позволяет сформировать билет с произвольным составом полномочий и произвольным сроком действия. Перечисление объектов каталога штатными запросами, не требующее повышенных прав, даёт нарушителю карту групп, ролей и путей повышения привилегий.

Общим свойством перечисленных техник является то, что ни одна из них не эксплуатирует дефект программного кода: все они используют штатные механизмы подтверждения личности в предусмотренном режиме. Классификаторы недостатков [32] и типовых способов атак [33] относят подобные случаи к недостаткам архитектуры и конфигурации, для которых идентификатор уязвимости не создаётся, вследствие чего оценка их критичности существующими калькуляторами невозможна.

Внедрение единого входа, сокращая число предъявлений аутентификационных данных, одновременно повышает последствия компрометации

сессии: маркер доступа, полученный нарушителем, открывает все связанные с ним сервисы без повторного подтверждения личности. Это обстоятельство означает, что вероятность компрометации учётной записи следует оценивать не только по стойкости факторов, но и по числу ресурсов, достижимых при однократном подтверждении личности.

Неоднородность уровней доверия аутентификации внутри одной организации существенна для риск-анализа. Она означает, что вероятность компрометации различных учётных записей различается на порядки при формально одинаковом выполнении нормативного требования о применении многофакторной аутентификации. Уровень доверия аутентификации, присвоенный конкретной учётной записи, является, таким образом, объективным, извлекаемым из конфигурации признаком, пригодным для построения шкалы вероятности компрометации. Такая шкала разрабатывается в подразделе 3.1 настоящей работы.

1.4 Сравнительный анализ средств управления учётными записями и аудита каталогов

Задачи управления доступом в организациях решаются средствами нескольких классов, различающихся объектом управления и характером получаемого результата. Средства класса IdM и IGA автоматизируют жизненный цикл учётной записи: создание по кадровому событию, согласование заявок на предоставление прав, периодическую аттестацию прав руководителями и блокировку при увольнении. Результатом их работы является приведение состава полномочий в соответствие с утверждённой ролевой моделью и перечень выявленных отклонений от неё.

Средства класса PAM управляют привилегированным доступом: хранят учётные данные административных записей, выдают полномочия на ограниченное время по заявке, записывают административные сессии и обеспечивают их последующий разбор. Они существенно сокращают время существования административных полномочий, однако оперируют только той частью субъектов

доступа, которая отнесена к привилегированным, и не рассматривают рядовые учётные записи, накопившие сопоставимый объём прав.

Средства аудита служб каталога выполняют разовое обследование конфигурации каталога и выявляют опасные сочетания прав: пути повышения привилегий через вложенность групп, делегирование административных полномочий, устаревшие протоколы аутентификации, учётные записи с неограниченным сроком действия пароля. Результат обследования представляется перечнем находок с качественной градацией их опасности и рекомендациями по устранению.

Средства поведенческого анализа и системы сбора событий безопасности решают обратную по времени задачу: они регистрируют состоявшиеся действия и выявляют отклонения от характерного поведения субъекта доступа - вход в нехарактерное время, обращение к нехарактерным ресурсам, множественные неуспешные попытки подтверждения личности. Оценка формируется по факту события и предназначена для реагирования, а не для предупреждения.

Средства класса IGA дополнительно реализуют проверку разделения полномочий, выявляя сочетания прав, недопустимые для одного субъекта доступа, и кампании аттестации, в ходе которых руководители подтверждают необходимость ранее выданных прав. Результативность этих механизмов ограничена их организационной природой: перечень недопустимых сочетаний составляется экспертно и редко пересматривается, а аттестация в отсутствие количественного показателя сводится к подтверждению текущего состояния, поскольку у руководителя нет основания отказать в правах, которыми работник уже пользуется.

Отечественные решения классов IdM и PAM, применяемые в организациях с требованиями по импортозамещению, повторяют функциональный состав зарубежных аналогов и обладают теми же ограничениями в части оценки риска: они управляют процессом предоставления прав и контролируют привилегированные сессии, но не выражают риск числом и не упорядочивают субъектов доступа по величине ожидаемого ущерба.

Отдельным ограничением средств поведенческого анализа является потребность в обучающей выборке. Модель поведения субъекта доступа строится по накопленным журналам за период наблюдения, вследствие чего вновь созданные учётные записи и записи с редкой активностью описываются недостоверно. Кроме того, постепенное накопление полномочий не порождает аномального поведения: субъект доступа продолжает работать в обычном режиме, а расширение его прав остаётся вне поля зрения средств, наблюдающих за действиями, а не за состоянием.

Сопоставление показывает, что перечисленные классы средств решают частные задачи и дополняют друг друга, но не образуют замкнутого цикла управления риском. Отсутствует звено, преобразующее состояние системы управления доступом в количественную оценку риска до наступления инцидента, - именно это звено разрабатывается в настоящей работе.

Сравнение перечисленных классов средств по единице анализа, характеру получаемой оценки и наличию количественной меры риска приведено в таблице 4.

Таблица 4 - Сравнительный анализ средств управления учётными записями и аудита каталогов

Класс средства	Решаемая задача	Единица анализа	Мера риска	Характер оценки
Средства управления жизненным циклом (IdM, IGA)	Предоставление, согласование и аттестация прав	Заявка на право, роль	Отсутствует	Соответствие ролевой модели
Средства управления привилегированным доступом (PAM)	Выдача административных прав на время, запись сессий	Административная сессия	Отсутствует	Контроль факта и длительности доступа
Средства аудита служб каталога	Выявление опасных сочетаний прав в каталоге	Находка в конфигурации каталога	Качественная градация	Разовое обследование
Средства поведенческого анализа	Выявление отклонений поведения субъекта доступа	Состоявшееся событие	Балльная оценка отклонения	Реагирование по факту события
Системы сбора событий безопасности	Накопление и корреляция событий	Событие журнала регистрации	Отсутствует	Последующий разбор инцидента

Из сопоставления следует, что ни один из применяемых классов средств не даёт количественной оценки риска, отнесённой к субъекту доступа. Средства управления жизненным циклом и аудита каталогов оперируют соответствием формальному правилу, средства управления привилегированным доступом - ограничением времени действия полномочий, средства поведенческого анализа - отклонением состоявшегося действия от нормы. Вопрос о том, какая из учётных записей организации создаёт наибольший риск до наступления инцидента и в каком порядке следует сокращать накопленные полномочия, остаётся без ответа.

1.5 Исследование количественных моделей риска применительно к субъектам доступа

Количественное выражение риска нарушения информационной безопасности разработано в ряде методик, различающихся единицей риск-анализа и способом получения числовой оценки. Стандарты менеджмента риска [12-13, 34] определяют риск как сочетание вероятности события и его последствий и предполагают качественную либо полуколичественную оценку по шкалам, значения которых назначаются экспертно. Руководство NIST SP 800-30 [14] использует матрицы соответствия вероятности и воздействия, также заполняемые экспертно и дающие оценку в порядковой шкале.

Методика OCTAVE Allegro [15] строит оценку вокруг информационного актива и профилей угроз, формируемых рабочей группой организации; единицей анализа выступает контейнер, в котором актив хранится, обрабатывается или передаётся. Факторная модель FAIR [16], принятая в качестве открытого стандарта [35], декомпозирует риск на частоту наступления событий потерь и величину потерь, а каждую из составляющих - на факторы, допускающие независимую оценку: частоту контакта с источником угрозы, вероятность действия, стойкость средств защиты и способность источника угрозы её преодолеть.

Метрики, применяемые для уязвимостей программного обеспечения, - системы оценки критичности [36-37] и прогнозирования эксплуатации [38] -

привязаны к зарегистрированной уязвимости, имеющей идентификатор в реестре CVE [39] и запись в базе NVD [40], обладающей идентификатором и накопленной статистикой применения. Субъект доступа таким идентификатором не обладает, вследствие чего перечисленные метрики к нему неприменимы непосредственно.

В работах отечественной научной школы разработаны методики оценки частоты и ущербности компьютерных атак [7], предложен аппарат формализации знаний об атаках и уязвимостях [8] и введено понятие риск-ландшафта как совокупного отображения рисков защищаемой системы с обоснованием подходов к его регулированию [9]. Указанные работы дают аппарат перехода от единичных оценок к оценке системы в целом, однако рассматривают в качестве единицы анализа узел сети либо уязвимость, а не субъекта доступа.

Сопоставление моделей оценки риска по применимости к учётным записям приведено в таблице 5.

Таблица 5 - Сравнение моделей оценки риска по применимости к субъектам доступа

Модель оценки риска	Единица риск-анализа	Характер оценки	Применимость к учётной записи
Стандарты менеджмента риска [12-13]	Актив организации	Качественная по экспертным шкалам	Требует экспертного описания каждой записи
Руководство по оценке рисков [14]	Информационная система	Порядковая по матрице соответствия	Не даёт сопоставимых числовых оценок
Методика OCTAVE Allegro [15]	Контейнер информационного актива	Качественная по профилям угроз	Субъект доступа отдельно не выделяется
Факторная модель FAIR [16]	Сценарий потерь	Количественная по частоте и величине потерь	Применима при наличии оценок факторов
Метрики критичности уязвимостей [36-38]	Зарегистрированная уязвимость	Количественная по базовым метрикам	Неприменима: идентификатор отсутствует
Методики риск-ландшафта [7-9]	Узел сети, атака	Количественная по частоте и ущербности	Требует переноса единицы анализа на субъекта

Проведённое сопоставление показывает, что наиболее пригодной основой для оценки риска компрометации учётной записи является факторная модель FAIR: она

не требует наличия идентификатора уязвимости, допускает раздельную оценку частоты и величины потерь и позволяет привязать обе составляющие к свойствам субъекта доступа - уровню доверия аутентификации с одной стороны и совокупности достижимых ресурсов с другой. Ограничением модели является экспертный характер исходных оценок, который в настоящей работе предлагается преодолеть, определяя отклонение состава полномочий субъекта от характерного для его должностной группы методами машинного обучения без учителя и учитывая полученную величину при расчёте первичного риска.

В общем виде мера риска нарушения информационной безопасности, связанного с компрометацией учётной записи, определяется произведением вероятности наступления события и величины наступающего при этом ущерба:

$$R = P \cdot U, \tag{1}$$

где R - мера риска компрометации учётной записи; P - вероятность компрометации учётной записи за рассматриваемый период; U - ущерб, наступающий при компрометации.

Факторная модель развивает это соотношение, представляя частоту событий потерь как произведение частоты попыток компрометации субъекта доступа и доли попыток, завершающихся успехом:

$$LEF = TEF \cdot V, \tag{2}$$

где LEF - частота событий потерь; TEF - частота попыток компрометации, определяемая доступностью субъекта доступа для нарушителя; V - доля успешных попыток, определяемая стойкостью применяемых факторов подтверждения личности.

Величина потерь определяется совокупностью информационных ресурсов, достижимых при использовании полномочий скомпрометированной учётной записи, и значимостью обрабатываемой на них информации. Такая постановка позволяет вычислять ущерб по фактическому составу прав субъекта доступа, не прибегая к экспертной оценке каждой учётной записи в отдельности.

Экономическая сторона регулирования риска выражается показателем возврата инвестиций в защиту, определяемым отношением предотвращённого ущерба к затратам на внедрение меры [41]:

$$ROSI = (ALE_1 - ALE_2 - C) / C, \quad (3)$$

где ALE_1 - ожидаемые годовые потери до внедрения меры защиты; ALE_2 - ожидаемые годовые потери после её внедрения; C - затраты на внедрение и сопровождение меры. Показатель применяется в четвёртой главе работы при обосновании выбора мер риск-регулирования.

Оценка отклонения состава полномочий субъекта доступа от характерного для его должностной группы выполняется методами обучения без учителя, поскольку размеченная выборка учётных записей с заранее известным признаком избыточности прав в организациях отсутствует и не может быть получена без длительного экспертного обследования. Из методов этого класса для настоящей работы предпочтителен изолирующий лес [42]: он не требует предположений о распределении признаков, устойчив к их разнородности, обладает линейной вычислительной сложностью относительно числа учётных записей и, что существенно для защищаемости результата, допускает интерпретацию - вклад отдельного признака в полученную оценку прослеживается по глубине обособления объекта в построенных деревьях.

Требование интерпретируемости является определяющим при выборе модели. Оценка риска, полученная средством защиты информации, должна быть объяснима специалисту, принимающему решение о сокращении полномочий конкретного работника, поскольку такое решение затрагивает исполнение работником должностных обязанностей. Модели, не допускающие объяснения полученного результата, для настоящей задачи непригодны независимо от достигаемого качества обнаружения.

1.6 Обоснование противоречий и формулировка задач работы

Выполненный анализ позволяет выявить противоречия, определяющие содержание работы. Каждое из них формулируется как расхождение между существующим состоянием информационного, методического или инструментального обеспечения и необходимостью его совершенствования для проактивного управления рисками нарушения информационной безопасности корпоративной системы управления доступом при компрометации учётных записей.

Первое противоречие связано с информационным обеспечением. Сведения, необходимые для риск-анализа системы управления доступом, распределены между службой каталога, журналами регистрации событий, банком данных угроз безопасности информации ФСТЭК России, перечнями CWE и CAPEC, матрицей MITRE ATT&CK и нормативными документами, задающими эталонное состояние системы (подразделы 1.1-1.3). Требования нормативных документов при этом адресованы процессу, а не отдельной учётной записи, а свойства субъектов доступа, порождающие риск, не сведены в единый перечень. Для проактивного риск-анализа эти сведения должны быть объединены в единую структуру, в которой недостаток управления доступом связан с техникой нарушителя и наступающим ущербом, а учётные записи описаны признаками, пригодными для машинной обработки. Такое объединение согласуется с принятым в отечественной научной школе подходом к формализации знаний и данных о кибератаках и уязвимостях [8], а представление угроз деревом развивает известный аппарат деревьев атак [43].

Второе противоречие связано с методиками риск-анализа. Метрики критичности уязвимостей к субъекту доступа неприменимы, стандарты менеджмента риска и методика OCTAVE Allegro опираются на экспертные шкалы, а средства управления учётными записями выражают результат соответствием ролевой модели (подразделы 1.4 и 1.5). Проактивная оценка риска компрометации учётной записи требует учёта уровня доверия аутентификации, объёма накопленных полномочий и отклонения их состава от характерного для должностной группы, причём последнее при отсутствии размеченной выборки определяется методами машинного обучения без учителя. Расчёт первичного риска опирается на факторную

модель FAIR, а последовательности перемещений нарушителя по ролям и группам описываются графами атак [44].

Третье противоречие связано с методиками управления рисками. Сокращение полномочий в существующей практике выполняется по результатам аттестации прав и по перечню формальных несоответствий ролевой модели (подраздел 1.4), тогда как проактивное регулирование риска требует моделирования мер защиты, их классификации по масштабности и профильности и расчёта остаточного риска для конкретных сценариев компрометации учётных записей.

Четвёртое противоречие связано со средствами автоматизации. Средства классов IdM, IGA и PAM и средства аудита служб каталога обеспечивают сбор сведений о состоянии системы управления доступом, но не выполняют количественной оценки риска (подраздел 1.4), тогда как оценка эффективности предлагаемых технических решений требует автоматизированного выполнения полного цикла проактивного управления риском - от идентификации сценария компрометации до количественной верификации эффективности выбранных мер по показателям ALE и ROSI.

Каждому противоречию ставится в соответствие задача работы, решение которой составляет содержание одной из последующих глав. Соответствие противоречий, задач и глав приведено в таблице 6.

Таблица 6 - Соответствие противоречий, задач и глав работы

Противоречие	Задача	Глава
Существующее информационное обеспечение не покрывает потребностей проактивного риск-анализа при компрометации учётных записей	Создание информационного обеспечения проактивного риск-анализа корпоративной системы управления доступом	2
Существующие методики риск-анализа не учитывают проактивных принципов оценки риска и возможностей машинного обучения	Создание аналитического обеспечения проактивной оценки риска с учётом аномального накопления полномочий	3
Существующие методики управления рисками не обеспечивают проактивного регулирования риска на основе результатов машинного обучения	Создание аналитического обеспечения проактивного регулирования риска и расчёта остаточного риска	4
Имеющиеся средства автоматизации не позволяют оценить эффективность предлагаемых технических решений	Формирование средств автоматизации и оценка эффективности предлагаемых мер защиты	5

Цель работы - повышение защищённости корпоративной системы управления доступом за счёт разработки интеллектуальной системы регулирования рисков - достигается последовательным решением перечисленных задач: созданное во второй главе информационное обеспечение служит входом аналитического обеспечения оценки рисков третьей главы, результаты оценки первичного риска - входом аналитического обеспечения регулирования рисков четвёртой главы, а автоматизация в пятой главе замыкает цикл количественной верификацией эффективности мер защиты.

Таким образом, выполненное в настоящей главе исследование аналогов позволило получить следующие результаты:

- установлено, что величина ущерба от компрометации учётной записи определяется не свойствами применённого нарушителем инструмента, а объёмом полномочий, накопленных этой записью, причём накопление полномочий носит системный характер и обусловлено устройством процессов управления доступом;

- установлено, что требования нормативных документов к управлению доступом и аутентификации адресованы процессу и выражены в терминах наличия меры, а не количественной оценки риска отдельной учётной записи;

- показано, что уровень доверия аутентификации, присвоенный учётной записи, является объективным, извлекаемым из конфигурации признаком, пригодным для построения шкалы вероятности компрометации;

- выполнен сравнительный анализ средств классов IdM, IGA и PAM, средств аудита служб каталога и поведенческого анализа, показавший, что ни одно из них не даёт количественной оценки риска, отнесённой к субъекту доступа;

- обоснован выбор факторной модели FAIR в качестве основы оценки риска компрометации учётной записи и изолирующего леса в качестве модели выявления аномального накопления полномочий;

- выявлены четыре противоречия и поставлены четыре задачи работы, каждой из которых соответствует одна из последующих глав.

Существенным итогом исследования аналогов является выбор единицы риск-анализа. Поскольку величина ущерба определяется совокупностью ресурсов,

достижимых при использовании полномочий конкретной учётной записи, а вероятность компрометации - уровнем доверия её аутентификации и доступностью для нарушителя, риск в настоящей работе оценивается применительно к субъекту доступа, а не к информационной системе в целом и не к отдельной роли.

Выявленные противоречия связаны между собой последовательно: без единой структуры сведений о свойствах учётных записей невозможна их количественная оценка, без оценки первичного риска - обоснованный выбор мер защиты, а без расчёта остаточного риска - верификация эффективности мер по показателю ROSI. Поэтому задачи работы решаются в порядке, совпадающем с порядком шагов проактивного управления риском, и результат каждой задачи служит исходными данными для последующей.

Проведённый анализ определяет и исходные данные для последующих глав. Во второй главе в качестве источников сведений о недостатках управления доступом используются меры групп ИАФ и УПД, руководство NIST SP 800-63B и ГОСТ Р 58833, в качестве источника сведений о способах компрометации - тактики Credential Access и Persistence матрицы MITRE ATT&CK, а в качестве экспериментального материала - синтетический каталог учётных записей и полномочий. В третьей главе уровни доверия аутентификации служат основой шкалы вероятности компрометации, а факторы модели FAIR - основой расчёта первичного риска. В четвёртой главе меры защиты, установленные нормативными документами, рассматриваются как множество вариантов регулирования, оцениваемых величиной остаточного риска. В пятой главе показатели ALE и ROSI используются как критерии эффективности мер защиты.

СПИСОК ЛИТЕРАТУРЫ

1 Verizon 2025 Data Breach Investigations Report. – Электрон. дан. – Режим доступа: https://www.verizon.com/business/resources/reports/dbir/. – Текст: электронный.

2 Утечки данных в России и мире: аналитический отчёт экспертно-аналитического центра InfoWatch. – Электрон. дан. – Режим доступа: https://www.infowatch.ru/analytics. – Текст: электронный.

3 Как российские компании защищаются от кибератак: результаты исследования Positive Technologies, февраль 2025 г. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/. – Текст: электронный.

4 Результаты тестов на проникновение: аналитический отчёт Positive Technologies. – Электрон. дан. – Режим доступа: https://www.ptsecurity.com/ru-ru/research/analytics/. – Текст: электронный.

5 NIST Special Publication 800-63B. Digital Identity Guidelines: Authentication and Lifecycle Management. – Электрон. дан. – Режим доступа: https://pages.nist.gov/800-63-3/sp800-63b.html. – Текст: электронный.

6 ГОСТ Р 58833-2020. Защита информации. Идентификация и аутентификация. Общие положения. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

7 Сердечный А.Л. Риск-анализ и прогнозирование частоты и ущербности компьютерных атак / А.Л. Сердечный, А.С. Маликова, А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.Н. Бартенев // Информация и безопасность. – 2021. – Т. 24, вып. 2. – С. 159-178. – Текст: непосредственный.

8 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин // Информация и безопасность. – 2024. – Т. 27, вып. 2. – С. 231-238. – Текст: непосредственный.

9 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А.

Остапенко, А.Ю. Пекло // Информация и безопасность. – 2023. – Т. 26, вып. 2. – С. 203-210. – Текст: непосредственный.

10 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко [и др.] // Информация и безопасность. – 2023. – Т. 26, вып. 3. – Текст: непосредственный.

11 Остапенко А.Г. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А.Г. Остапенко, М.Е. Волкова, Д.А. Нархов, А.А. Остапенко, А.В. Заряев, Т.Ю. Мирошниченко, П.Д. Федоров // Информация и безопасность. – 2020. – Т. 23, вып. 4. – С. 551-560. – Текст: непосредственный.

12 ГОСТ Р ИСО/МЭК 27005-2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. – Москва: Стандартинформ, 2011. – Текст: непосредственный.

13 ГОСТ Р ИСО 31000-2019. Менеджмент риска. Принципы и руководство. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

14 NIST Special Publication 800-30 Revision 1. Guide for Conducting Risk Assessments. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final. – Текст: электронный.

15 Caralli R.A. Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process / R.A. Caralli, J.F. Stevens, L.R. Young, W.R. Wilson. – Pittsburgh: Carnegie Mellon University, 2007. – Текст: непосредственный.

16 Freund J. Measuring and Managing Information Risk: A FAIR Approach / J. Freund, J. Jones. – Oxford: Butterworth-Heinemann, 2014. – Текст: непосредственный.

17 ГОСТ Р 50922-2006. Защита информации. Основные термины и определения. – Москва: Стандартинформ, 2008. – Текст: непосредственный.

18 Доктрина информационной безопасности Российской Федерации: утверждена Указом Президента Российской Федерации от 5 декабря 2016 г. № 646. – Электрон. дан. – Режим доступа:

http://publication.pravo.gov.ru/Document/View/0001201612060002. – Текст: электронный.

19 Об информации, информационных технологиях и о защите информации: Федеральный закон от 27 июля 2006 г. № 149-ФЗ. – Электрон. дан. – Режим доступа: http://www.consultant.ru/document/cons_doc_LAW_61798/. – Текст: электронный.

20 О персональных данных: Федеральный закон от 27 июля 2006 г. № 152-ФЗ. – Электрон. дан. – Режим доступа: http://www.consultant.ru/document/cons_doc_LAW_61801/. – Текст: электронный.

21 Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах: приказ ФСТЭК России от 11 февраля 2013 г. № 17. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-11-fevralya-2013-g-n-17. – Текст: электронный.

22 Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных: приказ ФСТЭК России от 18 февраля 2013 г. № 21. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-18-fevralya-2013-g-n-21. – Текст: электронный.

23 Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации: приказ ФСТЭК России от 25 декабря 2017 г. № 239. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/prikazy/prikaz-fstek-rossii-ot-25-dekabrya-2017-g-n-239. – Текст: электронный.

24 ГОСТ Р 57580.1-2017. Безопасность финансовых (банковских) операций. Защита информации финансовых организаций. Базовый состав организационных и технических мер. – Москва: Стандартинформ, 2017. – Текст: непосредственный.

25 Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных: постановление Правительства Российской Федерации от 1 ноября 2012 г. № 1119. – Электрон. дан.

– Режим доступа: http://www.consultant.ru/document/cons_doc_LAW_137356/. – Текст: электронный.

26 Методика оценки угроз безопасности информации: методический документ ФСТЭК России, утверждён 5 февраля 2021 г. – Электрон. дан. – Режим доступа: https://fstec.ru/dokumenty/vse-dokumenty/spetsialnye-normativnye-dokumenty/metodicheskij-dokument-ot-5-fevralya-2021-g. – Текст: электронный.

27 Банк данных угроз безопасности информации ФСТЭК России. – Электрон. дан. – Режим доступа: https://bdu.fstec.ru/threat. – Текст: электронный.

28 ГОСТ Р 56546-2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

29 ГОСТ Р 56545-2015. Защита информации. Уязвимости информационных систем. Правила описания уязвимостей. – Москва: Стандартинформ, 2015. – Текст: непосредственный.

30 NIST Special Publication 800-53 Revision 5. Security and Privacy Controls for Information Systems and Organizations. – Электрон. дан. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final. – Текст: электронный.

31 MITRE ATT&CK Enterprise Matrix. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

32 Common Weakness Enumeration (CWE). – Электрон. дан. – Режим доступа: https://cwe.mitre.org/. – Текст: электронный.

33 Common Attack Pattern Enumeration and Classification (CAPEC). – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

34 ГОСТ Р 58771-2019. Менеджмент риска. Технологии оценки риска. – Москва: Стандартинформ, 2020. – Текст: непосредственный.

35 The Open Group Standard. Risk Taxonomy (O-RT), Version 3.0.1. – Электрон. дан. – Режим доступа: https://publications.opengroup.org/. – Текст: электронный.

36 Common Vulnerability Scoring System v3.1: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/specification-document. – Текст: электронный.

37 Common Vulnerability Scoring System v4.0: Specification Document. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/specification-document. – Текст: электронный.

38 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

39 Common Vulnerabilities and Exposures (CVE). – Электрон. дан. – Режим доступа: https://www.cve.org/. – Текст: электронный.

40 National Vulnerability Database (NVD). – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

41 Sonnenreich W. Return On Security Investment (ROSI): A Practical Quantitative Model / W. Sonnenreich, J. Albanese, B. Stout // Journal of Research and Practice in Information Technology. – 2006. – Vol. 38, № 1. – P. 45-56. – Текст: непосредственный.

42 Liu F.T. Isolation Forest / F.T. Liu, K.M. Ting, Z.-H. Zhou // Proceedings of the 8th IEEE International Conference on Data Mining. – Pisa, 2008. – P. 413-422. – Текст: непосредственный.

43 Schneier B. Attack Trees / B. Schneier // Dr. Dobb’s Journal. – 1999. – Vol. 24, № 12. – P. 21-29. – Текст: непосредственный.

44 Sheyner O. Automated Generation and Analysis of Attack Graphs / O. Sheyner, J. Haines, S. Jha, R. Lippmann, J.M. Wing // Proceedings of the IEEE Symposium on Security and Privacy. – Oakland, 2002. – P. 273-284. – Текст: непосредственный.